

Plan de prueba de la tienda de Librería Fiordo

PF1495 · Hacking Ético en Aplicativos Web
Módulo 2 · MA03807 · Introducción al hacking ético

MODALIDAD

Grupal, de 4 a 5 personas.

APRENDIZAJE ESPERADO 4

Analizar aspectos metodológicos de hacking ético, distinguiendo fases, herramientas y marcos metodológicos acorde a las buenas prácticas y estándares de la industria

CRITERIOS DE EVALUACIÓN

- 4.1 Reconoce las fases del hacking ético para el testeo de la seguridad de un sistema acorde a las buenas prácticas de la industria.
- 4.2 Ejemplifica cada fase del ciclo de vida de un ataque mediante casos y ejemplos prácticos acorde las buenas prácticas de la industria.
- 4.3 Describe aspectos fundamentales de las metodologías de hacking ético acorde las buenas prácticas de la industria

Contexto

El equipo ya tiene el mapa de amenazas, las reglas de la prueba y su protocolo de conducta. Librería Fiordo (empresa ficticia) firmó la autorización: la prueba cubre solo la tienda web y tiene un plazo de 10 días hábiles.

Problema

La gerencia necesita saber cómo se hará la prueba, qué herramientas se usarán y qué recibirá al final. Como la tienda es ficticia, el equipo ensaya en OWASP Juice Shop, una tienda deliberadamente vulnerable que cada integrante instala en su propio equipo como réplica de laboratorio.

Solución

Un **plan de prueba por fases**, con su metodología, su calendario, un ensayo de laboratorio y la estructura del informe que recibirá la librería.

Desarrollo

1. **Metodología.** Expliquen cómo combinarán la guía de pruebas de OWASP y PTES, desde el acuerdo previo con la librería hasta el informe (criterio 4.3).
2. **Plan por fases.** Para reconocimiento, enumeración, explotación, post-explotación e informe, definan el objetivo, las actividades, las herramientas o técnicas (por ejemplo,

búsqueda de información pública, Nmap u OWASP ZAP), la evidencia esperada y los límites (criterio 4.1).

3. **Calendario.** Repartan los 10 días hábiles entre las fases, prioricen las funciones críticas (inicio de sesión, pago y panel de administración), reserven plazo para el informe y fijen cuándo se informa a la librería.
4. **Ensayo en el laboratorio.** En Juice Shop, hagan el reconocimiento y la enumeración: páginas, formularios y tecnologías visibles, con capturas. Para la explotación y la post-explotación, describan con un ejemplo qué se buscaría demostrar y cómo se documentaría la evidencia, sin desarrollar ataques (criterio 4.2).
5. **Estructura del informe.** Propongan el índice: resumen ejecutivo, alcance, metodología, hallazgos con su severidad, recomendaciones y anexos.
6. **Resumen para el foro.** El portavoz publica un resumen de una página o un video breve con el plan por fases.

Roles del equipo

Roten los roles respecto del ABPRO anterior:

- **Coordinador/a:** organiza el trabajo y arma el calendario.
- **Líder metodológico/a:** conduce la metodología y el plan por fases.
- **Responsable de laboratorio:** guía el ensayo en Juice Shop y reúne las capturas.
- **Documentador/a:** redacta la estructura del informe y la entrega.
- **Portavoz:** prepara el resumen para el foro. En equipos de 4, el documentador/a asume también este rol.

Entrega

Una entrega por equipo en esta Tarea: un PDF con la metodología, el plan por fases, el calendario, el ensayo con sus capturas, la estructura del informe, el enlace al resumen del foro y los nombres de los integrantes con su rol.